

Assignment 6 — JWT Auth (bcrypt + cookie)

Concept: Password hashing, token sign/verify, httpOnly cookie, protected route

Level	Medium-Hard
Time	2 hours
Files	staffModel.js , staffService.js , staffController.js , staff.route.js

Kya seekhoge

- Password kabhi plain me store kyun nahi karte
- `bcrypt.hash` aur `bcrypt.compare` kaise kaam karte hain
- JWT me kya daalna chahiye aur kya **bilkul nahi**
- `httpOnly` cookie localStorage se behtar kyun hai

Problem

Ek chhota **Staff login system** banao (bilkul apne auth jaisa, par khud se likhna hai).

Part A — Model

staffModel.js :

Field	Rules
name	String, required, 2-50
email	String, required, unique, lowercase, trim
password	String, required, min 6
department	String, enum: sales , support , warehouse

`pre("save")` hook lagao jo password hash kare:

```
staffSchema.pre("save", async function () {
  if (!this.isModified("password")) return;
  this.password = await bcrypt.hash(this.password, 10);
});
```

`isModified("password")` ka check kyun hai? Ye samajhna is assignment ka sabse important point hai.

Part B — 3 APIs

1. `POST /staff/register`

- Email pehle se ho to **409**
- Password service me hash **mat karo** — hook karega
- Response me password **kabhi mat bhejo**
- Success: `201`

2. `POST /staff/login`

- Email nahi mila **ya** password galat — **dono ka same message**: `"Invalid email or password"` (socho kyun)
- Token banao: `jwt.sign({ id, department }, secretKey, { expiresIn: "1h" })`
- Cookie set karo: `res.cookie("token", token, { httpOnly: true })`
- Success: `200`

3. `GET /staff/me` — **protected**

- `authMiddleware` se guzre

- Logged-in staff ki detail de (password ke bina)
- Token nahi hai to **401**

Part C — `authMiddleware` khud likho

Steps: 1. `req.cookies.token` se token lo — nahi hai to **401** 2. `jwt.verify(token, secretKey)` — **try/catch me rakho** 3. `decoded.id` se DB se **fresh** staff laao 4. Staff nahi mila to **401** 5. `req.user = staff` aur `next()`

Test list

Request	Expected
Register sahi data	201, password response me nahi
Register wahi email dobara	409
Login sahi password	200 + cookie set
Login galat password	401
Login aisa email jo hai hi nahi	401 (wahi message)
<code>/staff/me</code> bina login	401
<code>/staff/me</code> login ke baad	200
Token ke beech ka ek character badal ke bhejo	401

Soch ke batao

1. DB me password ka hash pada hai. Login ke waqt user plain password bhejta hai. `bcrypt.compare` **match kaise kar leta hai** jab hash se wapas password nikal hi nahi sakte?
2. Service me bhi `bcrypt.hash()` kar do (jab hook already kar raha hai) — kya hoga? **Ye galti bahut log karte hain.**
3. JWT ka payload encrypted hota hai ya sirf encoded? Iska matlab kya — payload me kya cheezein **kabhi nahi** daalni chahiye?
4. `httpOnly: true` na lagayein to kaunsa attack possible ho jaata hai?
5. Logout me cookie hata di. Kya wo token ab **mar** gaya? Agar kisi ne wo token pehle copy kar liya ho to?

Bonus

`/staff/logout` banao. `res.clearCookie("token", { httpOnly: true })`

Try karo — `httpOnly: true` hata ke `clearCookie` chalao. Cookie delete hoti hai? Nahi hoti to **kyun**?